

AdvocateAuroraHealth

Title: AAH HIT Security and Risk Management		Document Number: 23580
Document Type: ☒ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 10/02/2020
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 10/02/2023
		Effective Date: 10/02/2020
Scope: ☒ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

Advocate Aurora Health (AAH) Information and Information Resources must be available to AAH team members and patients, protected commensurate with their value and legal requirements, and must be administered in compliance with federal and state law. Reasonable measures shall be taken to protect and govern these assets against accidental or unauthorized access, disclosure, modification or destruction, as well as to reasonably assure the confidentiality, integrity, availability and authenticity of information. Reasonable measures shall also be taken to promote the availability, integrity and utility of information systems and the supporting infrastructure. This policy establishes the requirements for the AAH HIT Security and Risk Management Program in accordance with law and regulation to ensure compliance with the measures stated above.

II. SCOPE

This policy applies to all Advocate Aurora team members, Vendors, Information and Information Resources of Advocate Aurora Health and any entity or facility owned and controlled by Advocate Aurora Health.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Information: All information that is owned by Advocate Aurora or owned by Vendors but provided to Advocate Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a Vendor (e.g., a third-party service provider and/or its subcontractors).

Advocate Aurora Information Resources: Any media, software, hardware or other technology that supports the use, access, processing, storage or transmission of Advocate Aurora Information.

Payment Card Industry Data Security Standard (PCI DSS or PCI): PCI DSS is a proprietary information security standard for organizations that accept

branded credit cards (i.e., American Express, Discover, MasterCard, or Visa) for payment of services, goods or donations

Team Member: Anyone employed with Advocate Aurora Health who provides services on behalf of Advocate Aurora. All Advocate Aurora Team Members are expected to abide by Advocate Aurora policies and procedures. All Advocate Aurora Team Members are eligible to receive access to internal Advocate Aurora systems, as required to perform assigned duties.

Vendor: An external party providing paid goods or services to Advocate Aurora Health Care.

Subcontractor (also known as Third Party): An entity or person other than the vendor that offers to furnish goods or services of any kind under the contract of a vendor.

Risk Remediation- Risk Response in the larger NIST risk management framework. As defined in NIST publication 800-39, “risk response identifies, evaluates, decides on, and implements appropriate courses of action to accept, avoid, mitigate, share, or transfer risk to organizational operations and assets, individuals, other organizations, and the Nation, resulting from the operation and use of information systems.”

IV. POLICY

- A. HIT security and compliance controls will be implemented to reduce the risks to Advocate Aurora Information and Information Resources.
- B. HIT Enterprise Information Security (EIS) and Risk Management
 - 1. To comply with the HIPAA Security Rule as defined by the Code of Federal Regulations, 45 C.F.R. 160, 162 and 164 will develop EIS and Risk Management programs and standards.
 - a) Refer to the EIS Standard: Chief Information Security Officer. This ensures appointment and establishes responsibilities for a Chief Information Security Officer (CISO).
 - b) Refer to the EIS Standard: EIS Roles and Responsibilities. This establishes the program and roles and responsibilities within the program.
 - c) Refer to HIT Risk Management Program document. Refer to HIT Risk Management Risk Remediation Standard

V. PROCEDURE

N/A

VI. CROSS REFERENCES

N/A

VII. RESOURCES AND REFERENCES

HIPAA Security Rule	The HIPAA Security Rule establishes national standards which require covered entities to secure patient data that is stored or transferred electronically. Patient health information needs to be available to authorized users, but not improperly accessed or used. There are three categories of safeguards that organizations need to implement: administrative, physical and technical.45 C.F.R., Parts 160 and 164: HIPAA Privacy and Security Rules.
NIST Cybersecurity Framework v.1.1	The NIST Cybersecurity Framework (CSF) is a risk-based approach to managing cybersecurity risk and is composed of three parts: The Framework Core, the Framework Implementation Tiers, and the Framework Profiles. Each Framework component reinforces the connection between business/mission drivers and cybersecurity activities.
NIST 800-53 rev.4 & 800-53A	Provides a catalog of security and privacy controls for organizations and a process for selecting controls to protect operations. NIST 800-53 ensures organizations utilize robust systems and that security engineering principles are sufficiently trustworthy.
Special Publication 800-30	Guide for Conducting Risk Assessments
Special Publication 800-39	Managing Information Security Risk: Organization, Mission, and Information System View https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf
Special Publication 800-37	Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach
Special Publication 800-53	Recommended Security Controls for Federal Information Systems and Organizations
Special Publication 800-53A	Guide for Assessing the Security Controls in Federal Information Systems and Organizations: Building Effective Security Assessment Plans

PCI DSS 3.2.1	Payment Card Industry Data Security Standard (PCI DSS) is a requirement for any business that stores, processes, or transmits cardholder data. PCI DSS provides a baseline of technical and operational requirements designed to protect account data. The standard is broken into 12 high level requirements.
HITRUST CSFv9.3	<i>The HITRUST CSF is a framework that normalizes security and privacy requirements for organizations, including federal legislation (e.g., HIPAA), federal agency rules and guidance (e.g., NIST), state legislation (e.g., California Consumer Privacy Act), international regulation (e.g., GDPR), and industry frameworks (e.g., PCI, COBIT); and simplifies the myriad of requirements by providing a single-source solution, tailored to the needs of the organization. The HITRUST CSF is the only framework built to provide scalable security and privacy requirements based on the different risks and exposures of each unique organization. The HITRUST CSF contains 14 control categories, comprised of 49 control objectives and 156 control specifications.</i>
CIS Critical Security Controls v7	<i>Center for Internet Security Critical Security Controls are a set of cyber practices created to stop today's most pervasive and dangerous cyber-attacks. Organizations that apply the CIS Controls can significantly reduce their risk of cyberattack. Source: https://www.cisecurity.org/controls/cis-controls-list/ 11/5/19</i>
CSA Cloud Controls Matrix	https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v3-0-1/
OWASP Top Ten	https://owasp.org/www-project-top-ten/

VIII. ATTACHMENTS

N/A